



Sri Lanka Technology Campus

4th Year

Assignment & Submission Details	
Course Module	CCS4352 Application Security
Assignment	Assignment 2 (Group Submission)
Assessment Topic	Analysing a Court Case on Application Security
Selected Case	WM Morrison Supermarkets plc v Various Claimants [2020] UKSC 12
Submitted by	Thimeth Chathnuka (23UG1-0005) Dias Adrian (23UG1-0018) Sithumi Jayarathna (23UG1-0066)
Lecturer	Mr. A.J.H. Mohammed
Date of Submission	30 August 2026

Contents

1	Introduction	1
2	Case Selection	3
3	Case Summary: From Legitimate Access to Insider Data Breach	4
3.1	The Parties and Context	4
3.2	The Insider Threat: How the Breach Unfolded	4
3.3	Impact of the Breach	5
3.4	The Legal Journey	5
3.5	The Supreme Court's Reasoning	6
3.5.1	The Close Connection Test	6
3.5.2	Field of Activities Authorised by Morrisons	6
3.5.3	Skelton's Personal Motive	6
3.5.4	Opportunity, Causation and Wrongdoing	6
3.5.5	The Data Protection Act 1998 and Vicarious Liability	7
3.6	Application Security Significance	7
4	Analysis of Compliance and Security Failures	8
4.1	Least Privilege	8
4.2	Data Loss Prevention	8
4.3	Insider-Threat Monitoring	8
4.4	Detection and Incident Response	8
4.5	Access Governance	9
5	Implications for Organisations	10
5.1	Financial and Operational Impact	10
5.2	Legal and Regulatory Exposure	10
5.3	Human, Reputational and Governance Impact	10
6	Prevention Measures and Recommendations	11
6.1	Least Privilege and Just-in-Time Access [High Priority]	11
6.2	Data Loss Prevention and Endpoint Security [High Priority]	11
6.3	Insider-Threat Detection and Behavioural Monitoring [High Priority]	12
6.4	Access Governance and Segregation of Duties [Supporting Control]	12
6.5	Security Testing, Incident Response and Continuous Assurance [Supporting Control]	13
7	Conclusion	14
	Appendix 1: Judgment and Case Summary	16

1 Introduction

What is Application Security

Application security means keeping software applications from threats at every stage, during design, development and after they are released. It includes actions like writing code, running thorough tests, and applying patches to prevent attackers from using weak points in an app. Any application that deals with data, whether it is a banking app or a simple to-do list, must have some level of protection. Without application security, hidden flaws in the code can be exploited to steal, corrupt, or leak sensitive information.

Why Application Security Matters

Modern life depends on applications. When one has a flaw, it can impact thousands or even millions of people all at once. A security breach is not only about financial loss; it harms a company's reputation and shatters customer trust that took years to earn. In many countries, the law now requires organisations to protect the data they collect. This is why application security is no longer just a technical concern it has become a business priority.

Where Best Practices Are Needed Most

Best practices are most needed in places where people share financial data daily, such as banking apps, e-commerce sites, and government portals. Everyday examples include mobile payment apps, online food delivery platforms, and university student portals that store ID numbers and grades. Even social media apps need best practices because they hold personal messages and photos. When these systems are left unprotected, ordinary daily activities become targets for attackers.

Recent Breach Trends in the UK

The UK's Cyber Security Breaches Survey 2025 shows that about half of all businesses faced some kind of cyber breach or attack in the year. Of those attacks, 84% were delivered through phishing emails. For businesses, 50% experienced a breach, and for charities it was 32%. Phishing was the common method, used in 84% of business cases and 83% of charity cases.

More concerning is that only a small portion of these organisations had an incident response plan in place before the attack 22% of businesses and 19% of charities had a plan ready. That means the vast majority walked into a cyber attack without a path to respond.

This situation is worrying. The UK is a digital economy, yet many organisations still are not prepared. The gap between how cyber attacks happen and how ready companies are to deal with

them is real, and it shows a disconnect. If a breach happens, having a plan is not just helpful, it is essential. Too many organisations are still relying on hope instead of preparation.

The Situation in Sri Lanka

Sri Lanka has seen cyberattacks in recent years. These attacks hit government websites and even a government email system in 2023. That ransomware attack caused data loss because Sri Lanka was using unpatched versions of Exchange Server. Unlike the UK, Sri Lanka does not yet share yearly breach percentages with the public, and this lack shows a gap in cyber reporting. Sri Lanka recently started to build a formal cyber security authority through its Cyber Security Bill; as of 2023, Sri Lanka did not have a cyber security authority and the country was preparing to pass its Cyber Security Bill. This shows Sri Lanka is still catching up in both defence and transparency compared to more developed digital economies.

Human Behaviour as a Weak Link

Even with strong technical systems, humans remain one of the weakest links in application security. People often reuse the same password across many apps, click on suspicious links, and ignore software update notifications for weeks. Employees who have access to sensitive systems may not follow proper data-handling rules, especially when they are under stress or have personal grievances. These small, everyday behavioural gaps are often what attackers exploit instead of breaking through complex technical defences.

Let's discuss about the following problem.

2 Case Selection

Key Facts of the Case

Andrew Skelton, an internal auditor at Morrisons, leaked the payroll data of 98,998 employees between 2013 and 2014. He had a grudge after being warned for minor misconduct in 2013. He secretly copied the data onto a personal USB drive. He planned his attack using Tor software, a fake email account, and an untraceable pay-as-you-go phone to hide his identity. In January 2014 he uploaded the stolen data to a file-sharing website, and in March 2014 he sent copies to three UK newspapers. Skelton was later convicted in a criminal case and sentenced to eight years in prison. Morrisons spent over £2.26 million dealing with the breach and protecting employees. The civil litigation lasted six years and went through the High Court, the Court of Appeal, and the Supreme Court. On 1 April 2020, the Supreme Court ruled that Morrisons was not responsible for Skelton's actions. This case shows how one insider's deliberate misuse of access can cause years of financial trouble for a company.

Why This Case Was Selected

- Directly involves a data breach caused by weak access controls.
- Covers the Data Protection Act 1998, still relevant to current UK law.
- Criminal conduct falls under the Computer Misuse Act 1990, similar to Sri Lanka's law.
- Case passed through three court levels, showing full legal reasoning.
- Full judgment publicly available on the UK Supreme Court's official website.
- No accessible Sri Lankan judgment existed matching assignment requirements.
- Case is the largest data breach class action in UK history.
- Clearly links insider-threat behaviour to application security failures.

3 Case Summary: From Legitimate Access to Insider Data Breach

3.1 The Parties and Context

The party that filed the appeal in this case was WM Morrison Supermarkets plc, one of the major supermarket chains in the United Kingdom. The parties on the other side were 9,263 current and former employees of Morrisons whose personal payroll information had been shared unlawfully. Andrew Skelton, the auditor whose actions led to the leak, was not a party to the civil appeal, as he had already been dealt with in separate criminal proceedings.

3.2 The Insider Threat: How the Breach Unfolded

From Grievance to Legitimate Access. Skelton's path toward the breach began in July 2013, when he received a warning after disciplinary proceedings over minor misconduct. That event led him to develop a grudge against Morrisons. He started preparing for his attack before he ever gained access to the data: on 9 October 2013 he searched his work computer for Tor, software that hides a user's identity, a sign that he wanted to avoid detection, and on 14 November 2013 he bought a pay-as-you-go mobile phone, another step toward hiding his identity and avoiding being caught. Not long after, he was assigned a task that gave him access to payroll data for about 126,000 Morrisons employees, in order to support the company's audit with KPMG. That access was fully legitimate and authorised, granted for a specific purpose. Still, this case shows an issue in application security: an insider who has authorised access can quietly plan to abuse it before any technical system even notices something is wrong, since preparing for an attack often does not look like a security threat and can seem like routine activity, which is why monitoring for preparation is so difficult.

From Data Extraction to Organisational Response. Once Skelton had the payroll file, he quietly moved the dataset from his work computer to a personal USB thumb drive, an act of data extraction that took advantage of the device lacking removable-media controls. He then set up an email account using a colleague's name to frame that colleague, layering identity deception on top of the exfiltration. He used this fake identity, along with Tor and the untraceable phone, to upload the data of 98,998 employees to a public file-sharing website in January 2014. In March 2014, he anonymously mailed CDs containing the data to three UK newspapers, an external disclosure timed to coincide with Morrisons' results announcement. The breach surfaced only because one newspaper chose to alert Morrisons instead of publishing the material, rather than through any internal insider-threat detection mechanism. Morrisons responded by removing the data from the internet within hours, launching an internal investigation, and reporting the incident to the police, while also incurring costs for notifying and protecting affected employees.

This shows that the incident response was reasonably effective, but only after the preventive controls had already failed.

3.3 Impact of the Breach

The scale of this breach shows how a single insider can expose data far beyond what any normal business task would need. Skelton had access to payroll records of about **126,000** employees, yet ultimately exposed the personal data of **98,998** of them to the public internet and the press. This gap between the number of records he could technically reach and the far smaller number needed for his own audit task shows a serious failure to keep access limited to what was necessary. The breach was so serious that **9,263** current and former employees brought a claim against Morrisons, while Morrisons spent more than **£2.26 million** responding to the incident, paying for identity-protection measures, investigations, and employee notification. Skelton received an **eight-year** prison sentence, showing how a single disgruntled employee with access can damage an organisation on a scale usually linked to large external cyberattacks.

3.4 The Legal Journey

Court	What Happened / Decision
High Court	Langstaff J held that Morrisons was not a primary wrongdoer but was nevertheless vicariously liable for Skelton's actions. The court found a seamless chain of events linking Skelton's authorised handling of the data to his eventual disclosure of it, and held Morrisons liable under breach of statutory duty, misuse of private information, and breach of confidence.
Court of Appeal	The Court of Appeal (Sir Terence Etherton MR, Bean and Flaux LJ) upheld the High Court's decision. It held that Skelton's conduct was closely connected to his employment, and that his personal intention to hurt Morrisons was not important when deciding the issue of liability.
Supreme Court	The Supreme Court unanimously allowed Morrisons' appeal, reversing the decisions of the two lower courts. It held that Skelton's actions were not within the field of activities that Morrisons had authorised him to carry out, and that Morrisons could therefore not be held vicariously liable for what Skelton did.

3.5 The Supreme Court's Reasoning

3.5.1 The Close Connection Test

The Supreme Court used the well-known “close connection” test for vicarious liability, a rule that comes from *Dubai Aluminium Co Ltd v Salaam*. According to this test, an employer can only be held responsible for an employee's wrongdoing if there is a close connection between the work the person does and the wrongdoing that happens. The Supreme Court said that a simple time link or a causal link, meaning that the wrongdoing happened while the employee was working or because of that work, is not enough by itself to prove that connection. Lord Reed made this point clear.

3.5.2 Field of Activities Authorised by Morrisons

The Court drew a distinction between what Skelton was actually authorised to do and what he actually did. Morrisons had only authorised Skelton to transmit the payroll data to KPMG for the purposes of the audit. His later decision to upload the payroll data to a website and send it to newspapers was a completely different act, unrelated to the authorised task. Because publishing the payroll data was never part of Skelton's field of activities, the Court held that this later conduct fell outside the scope of his employment.

3.5.3 Skelton's Personal Motive

The Court placed a lot of emphasis on Skelton's motive. Instead of working to help Morrisons' business, Skelton was pursuing a personal grudge that came from an earlier warning. The Supreme Court drew a difference between conduct that genuinely helps the employer and conduct that tries to hurt the employer; if the conduct is intended to hurt the employer, it is not part of the employee's job duties. Because of this, the Court decided that Morrisons should not be held responsible for Skelton's actions.

3.5.4 Opportunity, Causation and Wrongdoing

The Court made a distinction between an employee simply having the opportunity to commit a wrong and the wrong actually being tied to the employee's authorised duties. Skelton's role gave him access to the data, but simply having access did not mean his misuse of it was part of his job. This point is important when dealing with insider threats in application security: even when someone has authorised access to a system, that does not stop them from misusing it on purpose, and it does not excuse what they do. The fact that access is legitimate does not make abuse of that access acceptable.

3.5.5 The Data Protection Act 1998 and Vicarious Liability

On a secondary point, the Supreme Court said that the Data Protection Act 1998 does not rule out vicarious liability for an employee who acts as a data controller and commits a statutory or common-law wrong. This finding did not change the result in favour of Morrisons, but the distinction matters: even though Morrisons did not face liability in this case, because Skelton's actions were outside his duties and came from personal motives, the Court made it clear that employers could still be held liable in other situations. The case therefore limits, but does not remove, the risk that employers face when data breaches are caused by insiders.

3.6 Application Security Significance

The Morrisons case shows that a serious security incident does not need an attacker exploiting a technical vulnerability; it can arise from an **insider threat**, where a trusted employee with **authorised access** deliberately misuses that access to do harm. Skelton was able to copy the payroll dataset onto removable media instead of just the small slice needed for his audit task, which marks a failure of **least privilege** and weak **access control**. The absence of any barrier to his USB transfer points to a missing **data loss prevention** system. The fact that Morrisons only learned of the breach from a newspaper tip, rather than through its own systems, further shows a gap in **monitoring** and **removable-media controls** that could have flagged his suspicious behaviour earlier. Although Morrisons' post-breach actions represented a reasonable **incident response**, this case makes clear that effective application security cannot focus only on defending against outsiders; it must also include controls that reduce the risk of privilege abuse and data exfiltration by those already inside the system.

4 Analysis of Compliance and Security Failures

4.1 Least Privilege

Skelton was given access to payroll data that covered about 126,000 employees, including bank account details and National Insurance numbers, so that he could complete a narrowly defined audit task. This shows the danger of giving standing access when only a small subset of payroll data is truly needed for the job. Applying least privilege by means of role-based access control, data minimisation, and time-limited, task-specific permissions would have kept Skelton's access to only the payroll records that were truly necessary for the KPMG audit.

4.2 Data Loss Prevention

Skelton copied the payroll dataset from his work computer onto a personal USB drive without any technical obstruction. Whether or not Morrisons had DLP controls in place, this incident shows why unrestricted removable-media access creates a risk for organisations that hold sensitive personal data. DLP measures such as USB restrictions, endpoint monitoring, egress controls, and alerts for bulk data extraction are designed to reduce this kind of risk.

4.3 Insider-Threat Monitoring

Before the breach, Skelton searched for Tor on his work computer, bought an untraceable phone, and made a fake email account to blame a colleague. These actions could show signs of an emerging insider threat, and the signs are stronger when paired with Skelton's disciplinary history. Insider-threat monitoring methods, such as User and Entity Behaviour Analytics (UEBA), anomaly detection, and linking unusual activity with privileged access, might have spotted the problem earlier, although it is not certain that these methods would have stopped the breach outright.

4.4 Detection and Incident Response

Morrisons only found out that the data was online after one of the newspapers they contacted told them about it, not because they discovered it themselves. This shows a gap between preventing something from happening and detecting when it does. Even where preventive controls fail, a company should still be able to notice when something strange is happening or when its own data is exposed outside the organisation. Continuous monitoring, checking for exposed data, and having clear alerting mechanisms help find problems faster. Morrisons acted quickly to remove the data and told the police once they knew about it, which shows that their overall response to the problem was reasonably effective.

4.5 Access Governance

Skelton kept access to sensitive payroll systems for a long time after he finished his assigned task, even though he had already received a disciplinary warning. This does not mean his access should automatically have been removed, but it does show how important it is to carry out regular, risk-based reviews of user access whenever an employee's role or situation changes. Requiring users to reconfirm their access rights, separating duties so no single person has too much control, and paying closer attention to users with special privileges can help ensure that access is withdrawn or reviewed once it is no longer necessary.

5 Implications for Organisations

5.1 Financial and Operational Impact

The Morrisons case shows that an organisation can face financial and operational damage from an insider breach even if it is later cleared of legal responsibility. Morrisons had to pay more than £2.26 million for incident response, notifying employees, and providing identity-protection services, and the company also spent over six years dealing with proceedings in three different courts. Even though the Supreme Court ruled that Morrisons was not vicariously liable, that decision did not erase the costs it had already incurred or the disruption it had experienced. This highlights that being legally exonerated does not mean an organisation avoids harm; legal outcomes and practical consequences can be very different, even when they arise from the same event.

5.2 Legal and Regulatory Exposure

The Supreme Court's finding that the Data Protection Act 1998 does not automatically remove vicarious liability in principle means that Morrisons' win depended on the particular facts of this case, tied to Skelton's motive and his field of activities, rather than on any blanket shield for employers. If the facts were different, an employer could still be held liable if an employee's data breach were more closely linked to that employee's authorised duties. Organisations therefore cannot view this judgment as a general protection against liability for employee-caused data breaches. Continuing to meet data-protection obligations remains a legal requirement, not just an optional safeguard.

5.3 Human, Reputational and Governance Impact

Beyond the financial aspects, the claimants reported that they felt anxiety and anger after their personal and financial data were exposed, showing the human cost that those affected must bear. When data is breached, the trust that employees and customers place in an organisation's ability to protect their information is harmed, and that trust does not return automatically once the legal case ends. Winning an appeal on liability did not undo the damage that employees had already suffered. In the end, this case reminds us that data protection is more than a technical issue; it is an organisational responsibility with lasting human consequences.

6 Prevention Measures and Recommendations

6.1 Least Privilege and Just-in-Time Access [High Priority]

Skelton had access to payroll details for 126,000 employees, a risk that went beyond what was needed for his specific audit task. If he had only been given the minimum access possible, he would have seen only the records needed for the KPMG audit. If he had been given just-in-time access, his permissions would have automatically ended once the task was done, making it harder for him to see so much data and limiting the time he could have used it improperly. This way of controlling access is especially important when dealing with information such as bank details and National Insurance numbers. Even with these restrictions, access still needs to allow proper audit work to happen without making the process too difficult for people who are authorised to do the job.

Recommended measures:

- Role-based access permissions
- Task-based access permissions
- Field-level restrictions
- Record-level restrictions
- Time-limited privileges
- Just-in-time privileges
- Automatic access expiry
- Minimum necessary dataset for audit activities

6.2 Data Loss Prevention and Endpoint Security [High Priority]

The moving of the payroll data from Skelton's work computer to a USB drive was a point at which technical controls could have stopped the attack. Data Loss Prevention systems could have detected the data being copied, while rules limiting removable-device use could have stopped unauthorised transfers completely. Endpoint monitoring could also have recorded large-scale copying and generated alerts for review. These controls would then govern the movement of data from initial access through to outside sharing. Such rules should still allow approved and monitored transfers to happen when real audit tasks require data to be moved.

Recommended measures:

- Limit the use of USB devices and other removable media
- Enforce data-loss-prevention rules for personal data

- Monitor every endpoint for security
- Alert on large bulk transfers
- Use approved and monitored channels for data export

6.3 Insider-Threat Detection and Behavioural Monitoring [High Priority]

Skelton's actions, searching for Tor, obtaining a phone, and setting up a fake email account, show how important behavioural monitoring can be when dealing with insider threats. Tools such as User and Entity Behaviour Analytics (UEBA) can help spot patterns by linking unusual activity to someone who has access to very sensitive information, flagging things that might need a closer look. It is important not to jump to conclusions, however; just because someone acts oddly does not mean they are doing something malicious, and treating unusual behaviour as automatic proof of malicious intent could lead to mistakes and make employees feel their privacy is being invaded. A better approach is a risk-based method that looks at clues together and involves human review of flagged cases. This combination reduces false alarms and keeps the process fair. Even if behavioural detection does not stop a threat completely, it gives teams a chance to intervene earlier, and early action can sometimes prevent further damage.

Recommended steps:

- Use behaviour analytics and detect unusual patterns
- Watch for access to and large downloads of sensitive data
- Set up notifications for odd activity involving anonymisation tools
- Identify signs of insider threats based on risk levels
- Have people check the most important alerts carefully

6.4 Access Governance and Segregation of Duties [Supporting Control]

The case also shows how important it is to have control over who can access large, important datasets. Checking who has access on a regular basis, and making sure they still need it, can help keep the right people with the right permissions as their jobs and situations change. Keeping the power to access, extract, and transmit information separate could stop one person from carrying out every step of an attack without anyone noticing. Requiring permission in advance for large data transfers would add a further level of control. These are recommended ways of managing access, not proof that Morrisons definitely lacked such controls.

Recommended measures:

- Periodic access recertification
- Risk-based privilege reviews

- Segregation of duties
- Independent approval for bulk exports
- Separate access, extraction, and transmission privileges

6.5 Security Testing, Incident Response and Continuous Assurance

[Supporting Control]

Security controls must also be regularly tested to ensure that weaknesses do not remain undetected. Access-control audits, data-export testing, and audit-log reviews can assess whether sensitive-data workflows operate as intended. At the same time, a tested incident-response plan enables rapid containment when preventive controls fail. Morrisons' removal of the exposed data, internal investigation, and reporting to the police demonstrate the value of a timely response after discovery. Organisations should therefore combine preventive and detective testing with rehearsed response procedures and continuous improvement.

Recommended measures:

- Regular access-control audits
- Testing of sensitive-data export pathways
- Regular audit-log reviews
- Incident-response and tabletop exercises
- Post-incident lessons-learned reviews

7 Conclusion

The Supreme Court’s decision in *WM Morrison Supermarkets plc v Various Claimants* [2020] UKSC 12 came down to a narrow legal point: whether Skelton’s sharing of payroll data was within the “field of activities” that Morrisons had allowed him to carry out. The court did not say the data breach was harmless or unimportant. Instead, it focused on the fact that Skelton acted out of revenge and went far beyond what he was authorised to do, transmitting data to KPMG. Because of this, the court ruled that Morrisons could not be held liable for his actions. This decision overturned both the High Court and the Court of Appeal.

The legal outcome should not hide how serious the real event was. One employee, with legitimate but poorly managed access, was able to extract, conceal, and release private information about nearly 100,000 people. That caused Morrisons more than £2.26 million in losses and six years of litigation. The case shows two things at once: first, that an employer can avoid responsibility under the strict rules of vicarious liability when an employee intentionally misuses their role for personal reasons; and second, that the company still has to bear all of the real consequences, the money lost, the disruption to operations, and the damage to reputation, all arising from weak controls over who could access the data, an absence of systems to stop data being leaked, and poor monitoring of insiders who might abuse their position.

Future challenges remain clear. Excessive standing access, unmonitored removable-media transfer, and weak behavioural and anomaly detection remain common problems for organisations in both the UK and Sri Lanka, and these gaps can lead to disputes similar to the one described in this case. Organisations will keep facing these problems unless they take active steps to address them. As organisations digitise payroll, health, and customer records, the number of endpoints grows; remote work and cloud storage add further ways to extract data, and insider misuse can grow alongside them, even as external cyberattacks such as phishing and ransomware continue to dominate reported incidents. Emerging risks, including employees exfiltrating data through personal cloud accounts, AI-assisted tools that can process and summarise stolen datasets, and the growing overlap between insider threats and third-party contractor access, all suggest that future application-security litigation will increasingly test the boundaries of employer liability in situations the Morrisons judgment did not directly address.

For jurisdictions such as Sri Lanka, where the Computer Crimes Act No. 24 of 2007 and the Personal Data Protection Act No. 9 of 2022 are still relatively young and largely untested in reported case law, the Morrisons case offers a clear warning. Unless organisations proactively adopt least-privilege access, data-loss prevention, and access governance now, they risk facing their own version of this dispute once local enforcement and litigation around data protection matures.

References

- [1] UK Supreme Court, “WM Morrison Supermarkets plc (Appellant) v Various Claimants (Respondents),” [2020] UKSC 12, 1 Apr. 2020. [Online]. Available: https://supremecourt.uk/uploads/WM_Morrison_Supermarkets_plc_Appellant_v_Various_Claimants_Respondents_e524b9da6f.pdf
- [2] “Various Claimants v Wm Morrison Supermarkets plc,” Wikipedia. [Online]. Available: https://en.wikipedia.org/wiki/Various_Claimants_v_Wm_Morrison_Supermarkets_plc
- [3] Various Claimants v WM Morrison Supermarkets plc, [2017] EWHC 3113 (QB); [2019] QB 772 (High Court of Justice).
- [4] Various Claimants v WM Morrison Supermarkets plc, [2018] EWCA Civ 2339; [2019] QB 772 (Court of Appeal).
- [5] CM Murray LLP, “Supreme Court decision in Morrison Supermarket & Claimants,” 2020. [Online]. Available: <https://cm-murray.com/knowledge/supreme-court-decision-in/>
- [6] Herbert Smith Freehills Kramer, “Morrisons wins Supreme Court appeal against finding of vicarious liability in data breach class action,” Apr. 2020. [Online]. Available: <https://www.hsfkramer.com/notes/data/2020-04/morrisons-wins-supreme-court-appeal-against-finding-of-vicarious-liability-in-data-breach-class-action>
- [7] Computer Crimes Act, No. 24 of 2007 (Sri Lanka).
- [8] Personal Data Protection Act, No. 9 of 2022 (Sri Lanka).
- [9] BBC News, “Morrisons staff lose payout bid in Supreme Court data leak case,” 1 Apr. 2020. [Online]. Available: <https://www.bbc.com/news/uk-england-leeds-52124997>

Appendix 1: Judgment and Case Summary

Case Summary: WM Morrison Supermarkets plc v Various Claimants [2020] UKSC 12

Case Details & Bench

Field	Details
Case ID / Citation	[2020] UKSC 12
Appeal From	[2018] EWCA Civ 2339
Court & Term	Supreme Court of the United Kingdom (UKSC) — Hilary Term 2020
Hearing Date	6–7 November 2019
Judgment Date	1 April 2020
Panel	Lady Hale, Lord Reed, Lord Kerr, Lord Hodge, Lord Lloyd-Jones
Delivered By	Lord Reed (unanimous)
Appellant	WM Morrison Supermarkets plc
Respondents	Various Claimants (9,263 current/former employees)

Facts & Procedural Background

Field	Details
The Incident	A senior internal auditor leaked payroll data of ~99,000 staff onto a public site as revenge for a workplace grievance.
Company Response	Rapidly removed data, alerted police/staff, and spent £2.26M on mitigation and identity protection.
Lower Courts	Found Morrisons vicariously liable, ruling the leak was closely linked to authorized work tasks.

Supreme Court Ruling & Findings

Field	Details
Final Decision	Appeal Allowed. Morrisons was held not vicariously liable.
Close Connection	Merely giving an employee access/opportunity to commit a wrong is insufficient to establish employer liability.
Role of Motive	An act done purely out of personal vengeance is an independent venture (a “frolic of his own”), outside employment.
DPA Coexistence	The DPA 1998 does not exclude vicarious liability, but the required common-law tests must still be satisfied.

Key Takeaway

Field	Details
Core Principle	Employers are not strictly liable for rogue data leaks committed solely for personal spite rather than advancing company business.

WM Morrison Supermarkets plc v Various Claimants
[2020] UKSC 12

1st April 2020

Reference: BBC News Paper

<https://www.bbc.com/news/uk-england-leeds-52124997>

